

SIMATS ENGINEERING

ASSESSMENT TOOL 3

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools : Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Annexure A

Scenario-Based

Code of Conduct:

I Sk Arshad Basha(192312336) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Sk Arshad Basha

Scenario-Based Assessment

Topic 1: Footprinting Tools – Conducting Competitive

Intelligence Q1. (L3 – Apply) – 15 Marks

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

Task: Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

ANSWER:

Scenario

A cybersecurity consultant has been assigned to perform a passive security assessment for NovaByte Solutions Pvt. Ltd. The consultant must collect publicly available information without directly interacting with the company's servers.

Tool 1: WHOIS

WHOIS is a footprinting tool used to retrieve domain registration information. It provides details such as the domain owner, registrar, creation date, expiry date, and DNS name servers.

Command

whois novabyte.com

Sample Output

```
kali@kali:~$ whois novabyte.com
Domain Name: NOVABYTE.COM
Registry Domain ID: 2679983642_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2024-12-28T10:15:04Z
Creation Date: 2022-03-18T09:34:12Z
Registry Expiry Date: 2030-03-18T09:34:12Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1068
Registrar Abuse Contact Email:
abuse@namecheap.com
Registrar Abuse Contact Phone: +1.6613102107

Registrant Organization:
NovaByte Solutions Pvt. Ltd.
Registrant Country: IN

Name Server: NS1.CLOUDFLARE.COM
Name Server: NS2.CLOUDFLARE.COM

DNSSEC: unsigned
kali@kali:~$
```

Information Collected

- Domain registration details
- Registrar information
- Domain creation and expiry dates
- Organization name
- Name servers

How it helps

WHOIS helps identify domain ownership and DNS infrastructure, which is useful during passive reconnaissance.

Tool 2: theHarvester

theHarvester is an open-source OSINT (Open Source Intelligence) tool used to gather employee email addresses, public hosts, and IP addresses from search engines and public sources.

Command

```
theHarvester -d novabyte.com -b google
```

Sample Output

A screenshot of a terminal window showing the output of theHarvester. The terminal title is 'kali@kali: ~'. The command entered is 'theHarvester -d novabyte.com -b google'. The output includes a stylized ASCII art logo for 'theHarvester', version '4.6.0', and credits to 'Christian Martorella' and 'Edge-Security Research'. It shows the target 'novabyte.com' and the search engine 'Google'. The results are categorized into 'Emails found', 'Hosts found', and 'IPs found'.

```
kali@kali:~$ theHarvester -d novabyte.com -b google

theHarvester
theHarvester 4.6.0
Coded by Christian Martorella
Edge-Security Research

[*] Target: novabyte.com
[*] Searching Google.
[*] No results found.

Emails found:
admin@novabyte.com
support@novabyte.com
hr@novabyte.com
careers@novabyte.com
contact@novabyte.com

Hosts found:
mail.novabyte.com
vpn.novabyte.com
portal.novabyte.com
dev.novabyte.com

IPs found:
103.56.81.21
103.56.81.22

kali@kali:~$
```

Information Collected

- Employee email addresses
- Public host names
- Public IP addresses

How it helps

It helps identify publicly available contact information and infrastructure that can be analyzed during competitive intelligence.

Tool 3: WhatWeb

About the Tool

WhatWeb identifies the technology stack used by a website, including the web server, CMS, programming language, frameworks, and security technologies.

Command

whatweb <https://novabyte.com>

Sample Output

```
kali@kali: ~  
kali@kali:~$ whatweb https://novabyte.com  
  
https://novabyte.com [200 OK]  
  
Title: NovaByte Solutions Pvt. Ltd.  
IP: 103.56.81.21  
Country: India  
Summary: Apache[2.4.58], PHP[8.2.7],  
WordPress[6.6], Bootstrap[5.3.2],  
jQuery[3.7.1], Cloudflare,  
TLS[1.3], HTTPServer[Apache/2.4.58  
(Ubuntu)], Script[text/javascript],  
Google-Analytics, Facebook-Pixel  
  
Detected Plugins:  
[ WordPress 6.6 ]  
Detected Frameworks:  
[ Bootstrap 5.3.2 ]  
JavaScript Libraries:  
[ jQuery 3.7.1 ]  
CDN:  
[ Cloudflare ]  
  
kali@kali:~$
```

Information Collected

- Web server
- PHP version
- CMS
- Framework
- JavaScript libraries
- CDN
- SSL configuration

How it helps

It identifies the technologies used by the website, allowing security professionals to understand the organization's web infrastructure.

Tool 4: Sublist3r

About the Tool:

Sublist3r is a subdomain enumeration tool used to discover publicly exposed subdomains.

Command

```
sublist3r -d novabyte.com
```

Sample Output

```
kali@kali: ~  
kali@kali:~$ sublist3r -d novabyte.com  
  
sublist3r  
  
# Coded By Ahmed Aboul-Ela - @aboul3la  
[+] Enumerating subdomains now for novabyte.com  
  
www.novabyte.com  
mail.novabyte.com  
vpn.novabyte.com  
ftp.novabyte.com  
portal.novabyte.com  
api.novabyte.com  
blog.novabyte.com  
dev.novabyte.com  
  
[+] Total Unique Subdomains Found: 8  
kali@kali:~$
```

Information Collected

- Public subdomains
- VPN server
- Mail server
- API server
- Development server

How it helps

It reveals additional services that may require further security assessment.

Conclusion

Using WHOIS, theHarvester, WhatWeb, and Sublist3r, the consultant successfully gathers domain registration details, employee email addresses, technology stack information, and publicly exposed subdomains without directly interacting with the company's systems.

Topic 2: DNS Zone Transfers Q2. (L3 – Apply) – 15 Marks

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

Task: Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

ANSWER:

Scenario

During an authorized penetration test, a security analyst suspects that the DNS server of NovaByte Solutions Pvt. Ltd. is misconfigured and may allow unauthorized DNS Zone Transfers.

Tool: Dig (Domain Information Groper)

About the Tool

The dig command is a DNS lookup utility used to query DNS records. It can also test whether a DNS server allows AXFR (Zone Transfer).

Step 1: Find the Name Servers

Command

dig NS novabyte.com

Sample Output

```
kali@kali: ~  
kali@kali:~$ dig NS novabyte.com  
  
;<<> DiG 9.18.36-1-Debian <<> NS novabyte.com  
;; global options: +cmd  
;; Got answer:  
;;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 12345  
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 0,  
ADDITIONAL: 1  
  
;; QUESTION SECTION:  
;novabyte.com.          IN      NS  
  
;; ANSWER SECTION:  
novabyte.com.          86400   IN      NS      ns1.novabyte.com.  
novabyte.com.          86400   IN      NS      ns2.novabyte.com.  
  
;; Query time: 48 msec  
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)  
;; WHEN: Wed May 15 11:20:30 IST 2024  
;; MSG SIZE  rcvd: 89  
  
kali@kali:~$
```

Step 2: Perform DNS Zone Transfer

Command

dig AXFR novabyte.com @ns1.novabyte.com

Sample Output

```
kali@kali: ~  
kali@kali:~$ dig AXFR novabyte.com @ns1.novabyte.com  
;<> DiG 9.18.36-1-Debian <> AXFR novabyte.com @ns1.novabyte.com  
;; global options: +cmd  
novabyte.com.      86400  IN  SOA  ns1.novabyte.com.  
admin.novabyte.com. 2024051501 3600 1800 604800 86400  
  
novabyte.com.      86400  IN  A    103.56.81.21  
www.novabyte.com.  86400  IN  A    103.56.81.21  
mail.novabyte.com. 86400  IN  A    103.56.81.22  
vpn.novabyte.com.  86400  IN  A    103.56.81.23  
ftp.novabyte.com.  86400  IN  A    103.56.81.24  
api.novabyte.com.  86400  IN  A    103.56.81.25  
portal.novabyte.com. 86400  IN  A    103.56.81.26  
dev.novabyte.com.  86400  IN  A    103.56.81.27  
novabyte.com.      86400  IN  NS   ns1.novabyte.com.  
novabyte.com.      86400  IN  NS   ns2.novabyte.com.  
  
;; Query time: 152 msec  
;; Transfer completed.  
kali@kali:~$
```

Alternative Command

host -l novabyte.com ns1.novabyte.com

Sample Output

```
kali@kali: ~  
kali@kali:~$ host -l novabyte.com ns1.novabyte.com  
  
Using domain server:  
Name:  ns1.novabyte.com  
Address: 103.56.81.10#53  
  
novabyte.com has address 103.56.81.21  
www.novabyte.com has address 103.56.81.21  
mail.novabyte.com has address 103.56.81.22  
vpn.novabyte.com has address 103.56.81.23  
ftp.novabyte.com has address 103.56.81.24  
api.novabyte.com has address 103.56.81.25  
portal.novabyte.com has address 103.56.81.26  
dev.novabyte.com has address 103.56.81.27  
ns1.novabyte.com has address 103.56.81.10  
ns2.novabyte.com has address 103.56.81.11  
kali@kali:~$
```

How it helps

If DNS Zone Transfer is enabled, an attacker or security analyst can obtain the organization's DNS records, making reconnaissance much easier. Therefore, DNS Zone Transfers should be restricted to authorized

secondary DNS servers.

Conclusion

The DNS server should be configured to allow AXFR requests only from trusted secondary DNS servers, preventing unauthorized disclosure of DNS information

Topic 3: Introduction to Social Engineering – Social Engineering Attacks and

Countermeasures Q3. (L3 – Apply) – 20 Marks

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

ANSWER:

Type of Attack

Phishing Attack

Phishing is a social engineering attack where attackers impersonate trusted organizations to trick users into revealing sensitive information such as usernames, passwords, or banking details.

Countermeasure 1 – Verify the Sender

Employees should carefully check the sender's email address before responding.

Example

Fake:

it-support@novabyte-security.com

Official:

it@novabyte.com

Benefit

Prevents users from trusting spoofed email addresses.

Countermeasure 2 – Do Not Click Suspicious Links

Hover the mouse over hyperlinks before clicking.

Example

Displayed Link:

<https://novabyte.com/login>

Actual Link:

<http://login-security-update.xyz>

Benefit

Helps detect fake or malicious websites.

Countermeasure 3 – Confirm with the IT Department

Employees should contact the IT department through official communication channels before entering credentials.

Benefit

Verifies whether the email is genuine.

Countermeasure 4 – Enable Multi-Factor Authentication (MFA)

Enable MFA using an authenticator app or OTP.

Benefit

Even if a password is stolen, attackers cannot log in without the second authentication factor.

Countermeasure 5 – Report Suspicious Emails

Employees should immediately report phishing emails to the organization's cybersecurity or IT team.

Benefit

Allows the organization to block malicious emails and alert other employees.

Conclusion

The email is a **Phishing Attack** designed to steal login credentials. Employees can protect themselves by verifying the sender, avoiding suspicious links, confirming requests with the IT department, enabling Multi-Factor Authentication (MFA), and reporting suspicious emails. These measures help prevent credential theft and strengthen the organization's overall security.

ChatGPT can make mistakes. Check important info.

RUBRICS FOR CALCULATION

Scenario Based Assessment

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Scenario	20%	Demonstrates clear and complete understanding of the scenario and context	Shows good understanding with minor gaps	Partial understanding; misses key aspects	Misinterprets or fails to understand the scenario
Identification of Key Issues	20%	Accurately identifies all relevant issues and factors involved	Identifies most key issues with minor omissions	Identifies limited issues; some irrelevant points	Unable to identify key issues
Application of Concepts	25%	Applies appropriate concepts effectively to address the scenario	Applies concepts with minor errors	Limited or partially correct application	Unable to apply relevant concepts
Decision Making	20%	Makes well-reasoned, logical decisions with strong rationale	Makes reasonable decisions with some justification	Makes weak decisions with limited justification	No clear decisions made or rationale provided
Clarity of Response	15%	Response is clear, structured, and logically presented	Generally clear with minor issues	Somewhat unclear or poorly structured	Disorganized and difficult to understand